Facilitator's Manual

The Solutions Dimension

An extension to the University of Washington Security Cards

28 Solutions cards · 4 optional inject cards · 6 gameplay variants

Mapped to CIS Critical Security Controls v8.1

Who this manual is for

Anyone running the activity: course instructors, teaching assistants, clinic staff, or students facilitating for their peers. **No security expertise is required to facilitate.** Everything you need to adjudicate is in Sections 6 and 7. If you read only two sections before your first session, read Section 3 (Quick Reference) and Section 7 (When to Intervene).

Version 2.0 ·

Contents

1. What This Game Is, and Is Not

The Security Cards were built to help groups think broadly about security threats. They stop at threat discovery on purpose: there is no scoring, no budget, and no defined end state. The Solutions dimension adds the other half of the professional task—choosing what to actually do about a threat, with limited money.

What the activity teaches. Prioritization under constraint. Students practice moving from a stated threat to a proportionate, affordable control, and justifying that choice out loud to someone who may disagree.

What it does not teach. It is not a simulation, a risk assessment methodology, or a substitute for technical instruction. A student who plays well is not thereby competent to advise a client. The activity is an on-ramp: it gives learners a vocabulary, a framework identifier they can look up afterward, and practice at one specific cognitive move.

The single most important thing to understand

The disagreement is the lesson. Students learning the card definitions is a side effect. The activity works when a team argues about which of two defensible options is better and has to articulate why. A session where everyone agreed quickly is a session that did not work, and Section 7 tells you what to do about it.

2. Before the Session

2.1. Materials

- **Original Security Cards deck** (42 cards, four dimensions), one per team. Teams may share if you are short.
- **Solutions deck**, one per team: 21 control cards, 7 modifier cards.
- **Risk matrix**, one per team. A printed 3×3 grid, or drawn on paper. Large enough to lay cards inside the cells.
- **Budget tokens**, 6 per team. Poker chips, paper squares, or coins. Physical tokens work substantially better than tallying on paper, because spending becomes visible and irreversible.
- **Session record sheet** (Appendix A), one per team.
- A timer everyone can see.

2.2. Printing and Setup

Print Solutions cards double-sided on card stock. If printing in grayscale, confirm that Solutions cards remain distinguishable from Human Impact cards — both use a blue family, and the icon frame shape is the backup differentiator.

Sort each Solutions deck into three piles before the session: Foundational (cards 1–13), Extended (14–18), Advanced (19–21), with modifiers (22–28) separate. You will deal from these piles rather than shuffling everything together.

2.3. Room and Group Size

Teams of **two to three**. Four is the maximum before someone stops talking. Seat teams so you can circulate to every table without walking behind anyone's chair.

For class size, divide by three and round up. The web version defaults to six teams and can be set to 8, 10, 12 or 16 from the facilitator panel, which covers a room of about sixty-four. Reducing the count later hides the higher-numbered teams rather than deleting them, so nothing is lost if you guess high.

One device drives per team. The board is shared, so if two people on the same team click at the same moment one set of changes overwrites the other. Everyone may join and watch — the app shows how many devices are on a team, and warns anyone who is not the driver — but agree who is typing before Phase 2 starts. On paper this problem does not exist, which is one reason the physical deck still generates more discussion.

Multiple teams playing simultaneously in one room works well and is the recommended arrangement, because the cross-team comparison at the end is where much of the learning lands. Expect it to be loud.

2.4. Choosing a Scenario

Do not improvise one. An invented scenario is the most common reason a session goes flat, and it also destroys cross-team comparison, since two teams arguing about different situations are not disagreeing about anything. Appendix B has ten ready to read aloud, each with an expert key and its own debrief questions. Scenarios 1, 2, 4 and 8 suit a first session.

2.5. Timing

Segment	Time	Note
Setup and rules explanation	5–7 min	Do not over-explain; see below
Phase 1: threat and placement	5–7 min	
Phase 2: budgeted defense	8–10 min	The longest phase
Phase 3: residual risk	4–5 min	
Cross-team comparison	5–8 min	Do not skip this
Debrief	5–10 min	Section 10
Total	**35–45 min**	Fits a 50-minute period

On explaining the rules

Explain Phase 1 only, then start. Explain Phase 2 when teams reach it, and Phase 3 when they reach that. Front-loading all three phases produces confused teams and wastes five minutes. The game is designed to be learned in motion.

3. Quick Reference

Keep this page in front of you during the session.

Deal	8 control cards + 3 modifier cards per team
Budget	6 tokens per team (see Section 8 for other tiers)
Costs	Foundational = 1 Extended = 2 Advanced = 3 Modifiers = 0
Modifiers	At most 2 played per round, each requires a stated justification
Matrix	3×3: likelihood (Not Likely / Likely / Very Likely) $\times$ severity (Not Severe / Severe / Very Severe)
Phase 1	Draw 1 card from each of the 4 original dimensions. Build a scenario. Place on matrix. *Severity must be justified by naming the Human Impact card.*
Phase 2	Deal 8 Solutions + 3 modifiers. Spend up to 6. For each purchase, say which safeguard addresses which part of the threat.
Phase 3	Re-place the same threat given what was bought. State what still gets through.
Your job	Time, budget arithmetic, modifier adjudication, and the interventions in Section 7. Nothing else.

#	Card	Cost	CIS Control
1	Software Updates	1	7 Continuous Vulnerability Mgmt
2	Social Engineering Awareness	1	14 Security Awareness
3	Deepfake & AI Fraud Awareness	1	14 Security Awareness
4	Identity & Access Management	1	6 Access Control Mgmt
5	Password & Authentication	1	5, 6 Account / Access Control
6	Backup & Recovery	1	11 Data Recovery
7	Account Lifecycle Management	1	5 Account Management
8	Physical Security	1	— (supports 1, 3)
9	Asset Inventory	1	1 Enterprise Asset Inventory
10	Software Inventory	1	2 Software Asset Inventory
11	Secure Configuration	1	4 Secure Configuration
12	Email & Browser Protections	1	9 Email & Browser
13	Incident Response Planning	1	17 Incident Response Mgmt
14	Encryption	2	3 Data Protection
15	Audit Logging & SIEM	2	8, 13 Log Mgmt / Monitoring
16	Endpoint Detection & Response	2	10, 13 Malware / Monitoring
17	Third-Party & Contractual	2	15 Service Provider Mgmt
18	Network Segmentation	2	12, 13 Network Infrastructure
19	Penetration Testing	3	18 Penetration Testing
20	Managed Detection & Response	3	8, 13, 17
21	Cyber Insurance & Risk Transfer	3	— (risk transfer)
22	Defense in Depth	0	Modifier
23	Fail Safe Defaults	0	Modifier
24	Least Privilege	0	Modifier (requires 4 or 7)
25	Human Factors	0	Modifier
26	Risk Acceptance	0	Modifier (extended)
27	Compensating Control	0	Modifier (extended)
28	Deferred Investment	0	Modifier (campaign play)

4. The Core Loop (Variant V6)

This is the recommended variant and the one everything else in this manual assumes.

4.1. Phase 1 — Threat and Placement (5–7 minutes)

Each team draws one card from each of the four original dimensions: Human Impact, Adversary's Motivations, Adversary's Resources, Adversary's Methods. They construct a short scenario in which all four appear, then place that threat on the risk matrix.

Say: *"Build a story where all four of these cards are true at once. It does not need to be realistic in every detail, but every card has to do some work in it."*

The severity rule. Teams must justify their severity placement by pointing at the Human Impact card and saying who specifically is harmed and how badly. This matters more than it looks. Novices rate severity by how sophisticated an attack *sounds*, so a technically impressive attack that harms nobody gets marked

Very Severe while a simple one that exposes a client's home address gets marked Not Severe. Requiring them to point at the Human Impact card corrects this without a lecture.

Record the coordinates on the session sheet. You will need them in Phase 3.

4.2. Phase 2 — Budgeted Defense (8–10 minutes)

Deal each team eight Solutions cards and three modifiers, and give them six tokens.

Deal from the sorted piles rather than at random. A workable default is six Foundational, one Extended, and one Advanced. If a team's threat obviously calls for a particular card, include it — the deal is a teaching instrument, not a lottery.

Teams purchase a portfolio. For each purchase they must say which safeguard addresses which element of the threat.

Say: *"Six tokens. Anything you do not spend is gone. For each card you buy, tell me which part of your scenario it touches."*

Enforce the arithmetic immediately. If a team overspends, correct it the moment you notice. The constraint is the entire mechanic, and a team that overspends unnoticed has not played the game.

4.3. Phase 3 — Residual Risk (4–5 minutes)

The team re-places the same threat on the matrix given what it bought, and states what would still get through.

Say: *"Same threat, same board. Where does it sit now that you have bought these? And tell me what still gets through, because something does."*

This is where the central lesson lands: controls reduce risk, they do not eliminate it. A team that moves its threat to Not Likely / Not Severe is almost always wrong, and the right response is a question rather than a correction — see Section 7.

4.4. Cross-Team Comparison (5–8 minutes)

Do not skip this. Have two teams that faced different threats state what they bought and why. The interesting question is never who was right; it is why two groups of reasonable people bought different things.

5. The Other Five Variants

Variant	What it does and when to use it	Time
V1 Scenario Generation	Four dimension cards, build an incident narrative. Use in week one, before Solutions cards are introduced at all. Lowest barrier of any variant.	8–10 min
V2 Risk Matrix Placement	Rank the seven Methods cards on the matrix for a named organization. Use to introduce likelihood and severity as separate axes. Pre-populate two or three cells to lower the entry cost.	10–15 min
V3 Solution Ranking	Deal 8 Solutions, rank the top three for a stated scenario. No budget. Use when you have under fifteen minutes.	7–10 min
V4 Control Mapping	Given an incident, identify which control failed. Use after students have seen the CIS framework once. Works well with real breach reports.	10 min
V5 Budgeted Defense	Phase 2 of the core loop, standalone. Use when you want the trade-off lesson without the matrix.	15–20 min
V6 Residual Risk Loop	The full three-phase loop. The recommended variant.	20–25 min

Sequencing across a course

V1 in week one. V2 once the risk matrix has been introduced in lecture. V3 or V4 as a short mid-term activity. V6 once students have played at least one earlier variant. Do not open with V6; it has three phases and a budget, and cold teams stall.

6. Adjudicating Modifier Cards

Modifiers cost nothing, which is why each one carries a justification requirement. **A modifier may be played only if the team supplies the justification the card demands. If it cannot, the card returns to the deck.** This is a rule, not a judgment call, and enforcing it is your job.

You do not need security expertise to adjudicate. The test in every case is whether the team said something *specific* rather than something *general*. Below, each modifier has an example of an answer to accept and one to reject.

Modifier	Accept	Reject
22 Defense in Depth	*"Email filtering stops the message; awareness training catches it if the filter misses. One is technical, one is human."*	*"We bought two things, so it is layered."* Two purchases failing the same way are one control bought twice.
23 Fail Safe Defaults	*"If the DNS filter goes down, the site resolves normally and staff can reach it, so it fails open. We would want it to block by default."*	*"It would fail safely."* No mechanism named.
24 Least Privilege	*"The volunteer coordinator sees donor payment records. She would lose that; she needs only names and shift times."*	*"Everyone should have less access."* No named person, no named loss.
25 Human Factors	*"Staff will share the one MFA phone at the front desk. We would need per-person enrollment."*	*"People are the weakest link."* A slogan, not a mechanism.
26 Risk Acceptance	*"We accept the risk of a physical break-in this year. The executive director owns that decision and it is reviewed in twelve months."*	*"We accept the rest of the risks."* No named risk, no named owner. A risk nobody owns has been ignored, not accepted.
27 Compensating Control	*"We cannot afford SIEM. We are substituting a monthly manual review of admin logins. It will not catch anything in real time."*	*"We will do it manually instead."* No statement of what is not covered.
28 Deferred Investment	*"We are capping at four and banking two. Meanwhile we are exposed to credential phishing for another year, and we would tell the client that."*	*"We will buy it next year."* No stated exposure, no duration.

The one-sentence test

If you are unsure, ask: *"Can you say that again naming a specific person, system, or failure?"* If they can, accept. If the answer stays general after one prompt, the card returns to the deck. Do not prompt twice — the requirement is the point.

7. When to Intervene

This is the section most worth reading twice.

7.1. Your Default Is Non-Intervention

New facilitators intervene far too early. A team sitting in silence for thirty seconds is usually thinking. A team arguing is usually learning. A team reaching a conclusion you consider wrong, and being corrected by a peer, has learned more than a team corrected by you.

Your standing job is small: keep time, enforce the budget arithmetic, adjudicate modifiers, and prevent the four situations in Section 7.4. Everything else is optional and most of it is counterproductive.

7.2. The Escalation Ladder

When you do intervene, use the lightest rung that works, and stop there.

Rung 1. Wait. Count to twenty before deciding a silence is a stall.

Rung 2. Ask an open question. *"What is the worst thing that happens in your scenario?"* Redirects without supplying content.

Rung 3. Point at a card. Physically point at the Methods card and say nothing. Astonishingly effective.

Rung 4. State a rule. *"Remember you have to say which part of the threat each purchase touches."*

Rung 5. Give direct instruction. Only when time is nearly gone or the team is genuinely stuck. Supplying an answer ends the learning for that team.

7.3. Intervention Triggers

Signal	Threshold	What to do
Total stall, nobody speaking	60 seconds	Rung 2. *"Read your Methods card out loud and tell me who it hurts."* Reading aloud restarts almost every stalled table.
One person doing all the talking	Two full minutes	Rung 2, addressed to a specific other person: *"Which card would you defend that nobody has picked yet?"* Do not name the dominant speaker or ask them to stop.
Agreement reached in under 90 seconds	Immediate	Rung 2. Argue the other side: *"Make the case for the card you just dismissed."* Fast consensus means the trade-off was not felt.
Technical jargon that others do not share	First occurrence	Rung 2, directed at the speaker: *"Say that again for someone who has not taken a security course."* Protects the non-majors without embarrassing anyone.
Buying cards without reference to the threat	Second purchase	Rung 3. Point at the Methods card. If needed, Rung 4: *"Which part of the scenario does that touch?"*

Signal	Threshold	What to do
Overspending the budget	Immediate	Rung 4. Correct at once. The constraint is the mechanic.
Modifier played without justification	Immediate	Rung 4. One prompt, then the card returns to the deck (Section 6).
Threat moved to Not Likely / Not Severe in Phase 3	Immediate	Rung 2. *“So this can no longer happen at all? What would an attacker with more time do?”* Almost always reveals the team has over-credited its controls.
“Just tell us the right answer”	After one deflection	Rung 2, then be honest: *“There is a better and a worse answer here, but not one right one. Tell me your reasoning and I will tell you where it is weak.”* Novices need to hear that the ambiguity is deliberate.
Discussion drifting into how to perform the attack	First occurrence	Rung 4. *“We are on the defending side of the table.”* Redirect without moralizing.
Team finishing five or more minutes early	Immediate	Rung 2. *“Your budget was cut by two tokens. What goes?”* A live budget cut is the best use of spare time.
Running out of time	3 min remaining	Rung 5. Have them commit to a portfolio even if unfinished; an incomplete decision is still assessable, an abandoned one is not.

7.4. Four Situations That Require Immediate Intervention

These four are different in kind from the table above. They are not pedagogical adjustments, and the escalation ladder does not apply — act at once.

1. A participant discloses a real vulnerability

Someone says their employer, their student organization, or their family business has a specific unaddressed weakness. **Stop the disclosure at the table.** Say: *“Let us not work through a real system in the open — come find me after.”* Then follow up privately and route it appropriately. Discussing a live vulnerability in a room of twenty people creates risk for a third party who did not consent to the conversation.

2. A scenario lands on someone’s personal experience

The Human Impact dimension includes Physical Wellbeing, Emotional Wellbeing, and Relationships, and the Methods dimension includes Manipulation or Coercion. A scenario about stalking, intimate partner surveillance, doxxing, or harassment can land hard on a participant with that history. Watch for someone going quiet, withdrawing, or leaving.

Offer an exit without requiring an explanation: *“This team can redraw the Impact card if you want a different scenario.”* Address the team, not the individual. Never require anyone to narrate a scenario aloud. Have a redraw available at every session as a standing, unremarkable option.

3. A participant is being spoken over or dismissed

Frequently a non-major being dismissed by a technical student. Intervene immediately and structurally rather than socially: *"Let us hear each person's top card before anyone argues."* Restructuring the turn order fixes this without anyone being reprimanded, and it protects the design goal that non-specialists can play.

4. Factual error that will propagate

Most wrong answers should be left for peers or the debrief. Intervene at once only when the error would be carried out of the room as a belief — for example, that encryption protects against phishing, that backups prevent a breach, or that insurance removes the obligation to notify. Correct briefly and without ceremony, then hand the discussion back.

7.5. When Not to Intervene

Leave these alone

- **Silence under twenty seconds.** It is thinking.
- **Disagreement, including heated disagreement.** It is the mechanism. Only intervene if it becomes personal rather than substantive.
- **A defensible choice you would not have made.** There are several good answers; yours is one of them. Ask why, do not correct.
- **A wrong answer another student is about to catch.** Wait three seconds. Peer correction is worth more than yours.
- **A team ignoring a card you think is obviously right.** Note it for the debrief. Steering purchases hollows out the exercise.
- **Slightly unrealistic scenarios.** The scenario is scaffolding, not the object of assessment. Do not audit plausibility.
- **A team spending everything on one expensive card.** That is a legitimate strategy with a real consequence. Let Phase 3 teach it.

8. Campaign Play Across a Term

Campaign play revisits the same client organization multiple times — typically weeks 3, 8, and 14. It is where the deck teaches roadmapping rather than one-shot selection. Use it only after teams have played the core loop at least once.

8.1. Budget by Organization

Budget is a property of the organization in the scenario, not of the game.

Budget	Organization modeled	CIS tier
5	Volunteer-run, no IT staff	Below IG1
6	**Default; small nonprofit**	**IG1**
10	One IT staff member	IG2
15	Dedicated security function	IG3

Running the same threat at two budget levels in consecutive sessions is one of the most effective things you can do with this deck. Students discover that the right answer changes with resources, which is the core insight of the Implementation Group model.

8.2. Deferred Investment and Threat Drift

A team playing **card 28 (Deferred Investment)** caps its spend at four, banks two, and receives ten points at the next engagement — the IG2 budget. In exchange, every threat left unmitigated drifts one cell toward *Very Likely* when the scenario is revisited.

Likelihood drifts. Severity does not. Severity is a property of who is harmed, which does not change because an organization delayed. Record drift on the session sheet; you are the bookkeeper across terms.

8.3. Realization

Because the matrix has only three likelihood states, a deferred threat reaches *Very Likely* within two engagements. A threat that survives *another* engagement unmitigated **realizes**.

Announce it. Do not roll dice. The outcome is determined entirely by what the team purchased in earlier engagements. In the web version this is automatic — press *Next engagement* rather than *New round*, and the app carries threats forward, applies drift to teams that deferred, resolves realization against everything they have ever bought, and grants the banked ten-point budget. The resolution below is what it applies, and what you apply by hand on paper:

Question	Purchased	Not purchased
Detection (15 or 20)	Discovered within days, internally	Discovered months later, by a third party or the press
Response (13)	They know who to call and in what order	Forfeit the first purchase of the next engagement to confusion
Recovery (6)	Data and systems restored	The loss is permanent
Financial (21)	Part of the cost is transferred	The full cost lands on the organization
Disclosure (17)	The provider is obliged to notify	They learn from someone else

The required artifact. The team narrates the incident to the room in the client's terms, using the Human Impact card to say who was harmed and how. This narration is the assessable product.

Why realization exists

Twenty-one of the twenty-eight cards are preventive, and novices spend on prevention first. A team that never experiences an incident never learns why detection, response, and recovery were worth points. Realization supplies that lesson retroactively without adding a card — their earlier portfolio decides how bad the day is.

Facilitator caution on realization

Realization is dramatic and can read as punishment. Frame it as consequence, not failure: *"This is what deferring looked like. Most organizations make exactly this trade."* A team that feels punished stops taking risks in later sessions, which defeats the purpose.

9. Optional Inject Cards

Four inject cards introduce adversity after purchase. **You play them; the team does not draw them.** Use at most one per round, after purchases are final but before Phase 3, and always require the team to answer the card’s question aloud before continuing.

Inject	Effect and when to play it
I1 Budget Cut	Withdraw two tokens; the team returns cards to that value. Play on a team that finished early or bought without deliberating.
I2 Vendor End of Life	Name one purchased card as withdrawn. They may substitute a Compensating Control if they can justify one. Play on a team over-relying on a single product.
I3 Staff Departure	Suspend any purchase requiring ongoing human attention (15, 13, 7, 9) until they name a successor. Play on a team that bought monitoring with nobody to watch it.
I4 Restricted Windfall	Three extra tokens, must be spent this round on new cards, unspent points lost. Play on a team that was too conservative.

Injects are for the second half of a course, once the base loop is internalized. **Do not use them during any session you are collecting research data from** — they introduce variance that is not held constant across teams.

10. Debrief

Five to ten minutes, and the highest-value part of the session. Each scenario in Appendix B carries its own questions, which are sharper than these because they name the specific trade-off that scenario was built around. Use those first, then any of the general ones below. Ask three or four, not all:

- Which purchase did your team argue about most, and how did you settle it?
- What did you want to buy and could not afford? What would you tell the client about that gap?
- Did anything you bought only help *after* the attack succeeded? Was that the points?
- Two teams here bought different portfolios for similar threats. Why?
- If your budget doubled, what would you add — and why that, before anything else?
- Which card would you cut from this deck entirely?

10.1. Misconceptions Worth Naming

Common belief	What to say
Controls eliminate risk	They reduce likelihood or impact. Phase 3 exists to show this; name it explicitly at debrief.
More expensive means better	Penetration testing costs three and is often the wrong buy for a small organization. Cost tracks Implementation Group, not value.
Awareness training solves phishing	It is one layer. Email filtering (card 12) is cheaper and does not depend on a tired person at 4pm.
Backups prevent breaches	They limit consequence. The data is still disclosed.
Everything must be fixed	Four risk treatments exist: avoid, mitigate, transfer, accept. Cards 21, 26 and 27 exist for the other three.
Technical sophistication equals severity	Severity is who gets harmed. That is why Phase 1 requires pointing at the Human Impact card.

11. Closing the Session

Discussion evaporates. A session that ends when the talking stops leaves students with a pleasant memory and no artifact, and the translation step below is the one clinic skill the rest of the game never asks for.

11.1. The Last Three Minutes

Ask every team for **one sentence: what would you actually tell this organization?**

The constraint is that it must be in the client's words, not the deck's. *"Turn on multi-factor authentication"* is a card name. *"Nobody should be able to move money on the strength of an email, even from the director"* is a recommendation. A student who can name a control but cannot say it to a nonprofit director has not finished the work.

Go around the room. Write them on the board. They take ninety seconds and they are the thing students remember in week eight.

Why this and not a summary

Summarizing is the facilitator's voice. This is theirs, and it is the only moment in the activity where a team has to commit to a single position with no cards to hide behind.

11.2. Before You Leave the Room

- **Export the session** if you are using the web version, or collect the record sheets if you are on paper. Do this before anyone closes a laptop.
- **Note which interventions you used**, at which rung. It is the only way to tell later whether you are intervening too early.
- **Reset or archive the board.** On paper this is shuffling the deck. The web version has two resets, and picking the wrong one is annoying rather than destructive. *New round* clears threats, hands, placements and purchases but leaves teams seated — use it when the same class plays a second scenario. *End session and clear board* empties everything including team membership, and keeps a timestamped copy first — use it at the end of a class, so the next one does not inherit a board that looks broken. A team can also undo its own purchases mid-round with *Clear our picks*, which leaves their hand and threat intact.
- **Do not score anything live.** Judging justifications while teams are still in the room changes how they talk. Score from the export afterwards.

11.3. What Comes Next in the Course

The activity is an on-ramp, so it should hand off to something.

Immediately after. Students' one-sentence recommendations go in their own notes. Ask them to keep them; they will be embarrassed by them later, which is the point.

Next session. Two options, both cheap. Re-run the same scenario at a different budget — an IG2 organization with ten points instead of six — and ask what changed. Or run a different scenario chosen to reward a control the class ignored last time. If nobody bought logging in week three, run scenario 7, where detection is the only lever that works.

Later in the term. The one-sentence recommendation becomes a paragraph, then a section of an actual client memo. When students write that memo, hand back their sentence from week three. The distance between the two is the clearest evidence of learning the course will produce, and it costs nothing to collect.

In campaign play. Do not reset. The same organization returns in a later week with drift applied to any threat left unmitigated, and the record sheet is what carries that forward. You are the bookkeeper across sessions (Section 8).

11.4. If the Session Went Badly

Two failure modes are worth naming, because both look like the activity not working when they are actually diagnostic.

Teams agreed too quickly and nobody argued. The budget was too loose or the deal too uniform. Cut to five points next time, or vary the piles between teams so cross-team comparison has something to compare.

Teams were overwhelmed and produced nothing. Too many cards at once, or you opened with V6. Drop to V3, deal six cards, pre-populate two cells of the risk matrix, and come back to the full loop in a later week.

Neither is a reason to abandon the activity. Both are settings.

12. Assessment

If you are grading, score the *justifications*, not the portfolio. Two teams may correctly buy different things.

Score	Level	Description
0	Assertion	Names a card with no reason. *"We bought backups."*
1	General reason	A reason that would apply to any threat. *"Backups are important for every organization."*
2	Threat-specific	Links the card to this threat. *"Ransomware encrypts the donor database, so backups get it back."*
3	Mechanism + safeguard	Links to this threat and names the mechanism or safeguard. *"Ransomware encrypts the donor database. Safeguard 11.4, an isolated copy, means the attacker cannot reach the backup from the same network."*

Expect mostly 1s in a first session and mostly 2s by the third. Level 3 requires the card backs to have been read, which is itself a useful signal.

13. Troubleshooting

Problem	Fix
Teams finish far too fast	Deal fewer Foundational and more Extended cards, so the budget binds harder. Or cut the budget to five.
Teams cannot finish in time	Deal six cards instead of eight. Pre-populate two cells of the risk matrix.
Nobody uses the modifiers	Deal them face-up and say they are free. Most teams do not notice they exist.
Every team buys the same three cards	Your deal is too uniform. Vary the piles between teams so the cross-team comparison has something to compare.
Scenarios are implausible	Leave it. Plausibility is not the learning objective, and auditing it costs time and morale.
One team is far ahead of the others	Play an inject (Section 9), or move them to a 10-point budget and a harder scenario.
Discussion is polite and flat	The budget is too loose or the deal is too easy. Six tokens against eight cards should hurt.

A. Session Record Sheet

Photocopy one per team per session. Retain across sessions for campaign play — you are the bookkeeper.

Team	
Session / week	
Organization	
Budget issued	
Drawn cards (4 dims)	
Scenario (one line)	
Phase 1 placement	Likelihood: ________ Severity: ________
Severity justified by which Human Impact card?	
Phase 2 purchases and cost	
Modifiers played / accepted?	
Tokens spent	
Phase 3 placement	Likelihood: ________ Severity: ________
Stated residual risk	
Justification score (0–3)	
Deferred? Drift carried forward	
Interventions used (rung)	

B. Scenario Library

Improvised scenarios are the most common reason a session goes flat, and they also make cross-team comparison meaningless, since two teams arguing about different situations are not disagreeing about anything. The ten scenarios below are ready to read aloud.

Each carries a **teaching target**: the specific thing it is built to surface. Each also carries an **expert key** naming which controls are strong, partial, or weak *for that situation*. The key is a scoring aid, not an answer sheet — a team that buys a “partial” card and defends it well has done better work than one that buys a “strong” card without reasoning.

#	Organization and teaching target	Budget	Tier	Care
1	Food bank — severity is consequence, not sophistication	6	Found.	
2	Rural health clinic — recovery beats prevention once it has happened	6	Found.	
3	Domestic violence shelter — when impact is physical safety	6	Found.	•
4	Community land trust — the boring control is the right one	5	Found.	
5	School district — you cannot buy your way out of a vendor’s breach	10	Ext.	
6	Municipal water utility — the correct answer costs one point	10	Ext.	
7	Legal aid office — prevention fails, detection is the only lever	10	Ext.	•
8	Public library — you cannot protect what you do not know exists	6	Found.	
9	Arts nonprofit — what a grant paid for and nobody maintains	6	Camp.	
10	Animal rescue — the obligation that survives the incident	10	Ext.	

• Content that may land on a participant’s personal experience. Offer the redraw described in Section 7.4 *before* reading it, addressed to the team rather than to any individual.

1. Payroll Redirection at Harborview Food Bank BUDGET 6 FOUNDATIONAL

Teaching target. Severity is a property of who gets harmed, not of how clever the attack was. The strongest control here is free and procedural.

Read aloud. Harborview Food Bank has three paid staff and about forty volunteers. The bookkeeper works two days a week from home. Last Tuesday she received an email that appeared to come from the board treasurer, in his usual phrasing, asking her to update the payroll provider’s bank details before Friday’s run. A follow-up voicemail in his voice confirmed it. Friday’s payroll is eighteen thousand dollars, roughly a month of operating cash.

Suggested draw. Method: Manipulation or Coercion · Impact: Financial Wellbeing · Resources: Artificial Intelligence · Motivation: Personal Gain

Expert key. **Strong:** Social Engineering Awareness (2), Deepfake and AI Fraud Awareness (3), Email and Browser Protections (12). **Partial:** Password and Authentication (5), Incident Response Planning (13). **Weak here:** Encryption (14), Network Segmentation (18), Penetration Testing (19) — none of them touch a human being persuaded to type a new account number.

Debrief.

- The attack was technically trivial and you rated it Very Severe. What made it severe, and would it have been severe at a different organization?
- Nobody can buy a callback rule. Which of your purchases would you trade for one sentence in a written procedure?

- The voice on the phone was cloned. Does awareness training still work when familiarity stops being evidence?

2. Ransomware at Cedar Ridge Health Clinic

BUDGET 6 FOUNDATIONAL

Teaching target. Once an incident has happened, prevention cards are worth nothing and recovery cards are worth everything. Teams that spent all six points on prevention have to explain their Monday morning.
Read aloud. Cedar Ridge is a two-provider clinic serving about nine hundred patients in a county with no other primary care. On Monday morning the front desk cannot open the scheduling system. Every file on the shared drive has a new extension, and a text file on the desktop asks for payment in cryptocurrency. The practice manager thinks there is a backup, but it is on a drive plugged into the same server, and nobody has ever restored from it.
Suggested draw. Method: Technological Attack · Impact: Physical Wellbeing · Resources: Money · Motivation: Personal Gain
Expert key. **Strong:** Backup and Recovery (6) — specifically the isolated copy, since a backup on the same server is now encrypted too; Incident Response Planning (13); Endpoint Detection and Response (16). **Partial:** Software Updates (1), Email and Browser Protections (12), Cyber Insurance (21). **Weak here:** Penetration Testing (19) — an annual report does not help on the morning it happens.
Debrief.

- The backup existed and was useless. What is the difference between having a backup and having a recovery?
- Impact is Physical Wellbeing, not Financial. What does a clinic without scheduling actually do to a patient?
- If you bought only prevention, describe your Monday.

3. A Laptop Leaves the Building — Wilder House

BUDGET 6 FOUNDATIONAL

Teaching target. When Human Impact is physical safety, ordinary controls carry stakes students have not previously attached to them.
Handle with care. This scenario involves a shelter and the safety of people escaping violence. Offer the redraw to the team before reading it, and do not require anyone to narrate.
Read aloud. Wilder House is a twelve-bed shelter. A caseworker's laptop was taken from her car in a grocery store parking lot on Saturday. It holds an offline copy of the intake spreadsheet: names, dates of birth, the schools children attend, and current addresses for eleven families. The laptop has a login password. Nothing else.
Suggested draw. Method: Physical Attack · Impact: Physical Wellbeing · Resources: Entitlement · Motivation: Curiosity
Expert key. **Strong:** Encryption (14) — full-disk encryption makes this a hardware loss rather than a disclosure; Physical Security (8); Identity and Access Management (4), on why an offline copy existed at all. **Partial:** Asset Inventory (9), Incident Response Planning (13). **Weak here:** Audit Logging (15), Network Segmentation (18) — the device is gone and off the network.
Debrief.

- A login password and full-disk encryption feel similar to a non-specialist. What is the actual difference to whoever has the laptop now?
- The spreadsheet was a convenience copy. Which control stops a convenience copy from existing, and what does the caseworker lose when it does?

- Who has to be told, how quickly, and what do you say to eleven families?

4. The Volunteer Who Left in 2021 — Fairmount Land Trust BUDGET 5 FOUNDATIONAL

Teaching target. The strongest answer is the least interesting card in the deck. Teams reliably overlook it and buy something exciting instead.
Read aloud. Fairmount Land Trust has two staff and a rotating pool of volunteers. A volunteer who managed the donation platform in 2021 moved out of state and stopped responding. Last month a two-hundred-dollar test transaction appeared, then reversed. The executive director does not know how many people still have logins, and the platform bills annually to a credit card nobody can locate the statement for.
Suggested draw. Method: Processes · Impact: Financial Wellbeing · Resources: Entitlement · Motivation: Personal Gain
Expert key. **Strong:** Account Lifecycle Management (7), Identity and Access Management (4). **Partial:** Asset Inventory (9), Software Inventory (10), Audit Logging (15). **Weak here:** Social Engineering Awareness (2) — nobody was tricked; a door was left open.
Debrief.

- Nobody attacked this organization. Is this a security incident?
- The right answer costs one point and takes an afternoon. Why is it the one nobody does?
- How would this organization even produce a list of who has access?

5. The Vendor's Breach — Northbridge School District BUDGET 10 EXTENDED

Teaching target. Sometimes nothing you can buy internally helps, and the only real control was written a year earlier in a contract.
Read aloud. Northbridge is a rural district of four schools. Their bus routing and student scheduling run on a hosted platform used by two hundred districts. On Thursday a reporter calls the superintendent for comment on a breach at that vendor. The district has had no notification. The vendor's support line has a recorded message. The data includes student names, home addresses, and bus stop times.
Suggested draw. Method: Indirect Attack · Impact: Relationships · Resources: Technical Expertise · Motivation: Personal Gain
Expert key. **Strong:** Third-Party and Contractual Controls (17), Incident Response Planning (13). **Partial:** Asset Inventory (9) extended to data location, Cyber Insurance (21). **Weak here:** nearly everything else — Endpoint Detection, Segmentation, Secure Configuration and Software Updates all protect systems the district does not own.
Debrief.

- Half your deck is useless here. What does that tell you about where a small organization's real risk lives?
- The superintendent learned from a reporter. What clause would have changed that, and when would it have had to be written?
- Bus stop times plus home addresses. Which Human Impact card is this really?

6. Debug Mode in Production — Millbrook Water Authority BUDGET 10 EXTENDED

Teaching target. A one-point Foundational card beats every expensive option on the table. Teams with ten points often overspend here.

Read aloud. Millbrook Water Authority serves eleven thousand residents. Their public site posts water quality reports and lets residents pay bills. A contractor built it four years ago and moved on. A resident emails to say that adding a parameter to a URL shows an administrative page listing every account and a button labelled "post notice." The page has no login.
Suggested draw. Method: Processes · Impact: Relationships · Resources: Technical Expertise · Motivation: Politics
Expert key. **Strong:** Secure Configuration (11) — debug mode in production is a configuration failure; Identity and Access Management (4). **Partial:** Penetration Testing (19) would have found it, at three points; Software Inventory (10); Third-Party and Contractual (17), on the contractor who left. **Weak here:** Social Engineering Awareness (2), Backup and Recovery (6).
Debrief.

- You had ten points. What is the cheapest purchase that actually closes this?
- Penetration testing would have found it. Was it worth three points here, and what would have to be true first?
- A utility can post public notices. What is the worst version of this that does not involve stealing anything?

7. The Trusted Paralegal — Eastgate Legal Aid   BUDGET 10   EXTENDED

Teaching target. Every preventive control in the deck fails, because the person had legitimate access. Detection is the only remaining lever.
Handle with care. Involves surveillance of a person by someone they trusted. Offer the redraw.
Read aloud. Eastgate Legal Aid handles housing and immigration matters. A paralegal of six years has legitimate access to the case system. A client reports that her landlord seems to know the contents of a filing that has not been served. The paralegal and the landlord attend the same church. There is no evidence of an intrusion, and nothing in the system is broken.
Suggested draw. Method: Processes · Impact: Emotional Wellbeing · Resources: Entitlement · Motivation: Desire or Obsession
Expert key. **Strong:** Audit Logging and SIEM (15) — who read which file and when is the only question that can be answered; Identity and Access Management (4) with Least Privilege (24); Managed Detection and Response (20) if affordable. **Partial:** Incident Response Planning (13), Third-Party and Contractual (17) on employment terms. **Weak here:** Email and Browser Protections (12), Encryption (14), Software Updates (1) — the access was authorized.
Debrief.

- Which of your purchases would have stopped this? If none, what would you tell the client you can offer instead?
- Logging tells you afterward. Is a control that only works afterward worth two of ten points?
- Least Privilege has a cost that is not measured in points. What does the paralegal lose, and is the trade right?

8. The Camera Nobody Remembered — Delridge Public Library   BUDGET 6   FOUNDATIONAL

Teaching target. Asset inventory is a precondition for everything else. Teams cannot defend what they have not enumerated.
Read aloud. Delridge Public Library has public wifi, twenty patron computers, a self-checkout system, and four security cameras installed by a since-dissolved vendor in 2016. The county IT contractor reports that

traffic is leaving the library network at three in the morning, and traces it to a device nobody on staff can identify. The library's network is flat: everything is on the same wifi, including the circulation desk.

Suggested draw. Method: Technological Attack · Impact: Relationships · Resources: Technical Expertise · Motivation: Curiosity

Expert key. **Strong:** Asset Inventory (9), Network Segmentation (18) if the budget reaches it, Secure Configuration (11) for the 2016 default credentials. **Partial:** Software Inventory (10), Audit Logging (15). **Weak here:** Social Engineering Awareness (2), Backup and Recovery (6).

Debrief.

- At six points, segmentation may be out of reach. What do you buy first, and what do you tell the library board about the rest?
- The camera has been there for a decade. Which control would have caught it in year one, and how much does that control cost?
- Patron borrowing records are legally protected in many states. Does that change your ranking?

9. What the Grant Paid For — Ridgeway Arts Collective BUDGET 6 CAMPAIGN

Teaching target. Built for multi-engagement play. The right move is often to defer, and the card that lets you defer is the one that makes the cost of deferring visible.

Read aloud. Ridgeway Arts received a technology grant in 2019 that paid for a donor database, a website, and a year of support. The grant ended. The database runs a version the vendor stopped patching in 2022. Migrating costs about four thousand dollars the collective does not have. The board meets quarterly. Nothing has gone wrong yet.

Suggested draw. Method: Technological Attack · Impact: Financial Wellbeing · Resources: Technical Expertise · Motivation: Personal Gain

Expert key. **Strong:** Software Inventory (10), Deferred Investment (28) played honestly with a stated exposure, Backup and Recovery (6). **Partial:** Network Segmentation (18) to isolate the unsupported system, Compensating Control (27), Risk Acceptance (26) with a named owner. **Weak here:** Software Updates (1) — there are no patches to apply, which is the whole problem, and teams reliably buy it anyway.

Debrief.

- Someone bought Software Updates. What happens when the vendor has stopped shipping them?
- If you deferred, name the exposure and say for how long. Would you put that in writing to the board?
- Revisit this in a later session and drift the threat. Was deferring still the right call?

10. Donor Records in a Shared Mailbox — Second Chance Animal Rescue BUDGET 10 EXTENDED

Teaching target. Obligations survive the incident. Notification and disclosure are not technical controls and cannot be bought after the fact.

Read aloud. Second Chance runs on donations and a shared mailbox that six volunteers access with the same password. On Friday the mailbox began sending donation appeals to the entire contact list from an address that is not theirs. The mailbox holds four years of correspondence, including scanned cheques with routing numbers and a spreadsheet of major donors.

Suggested draw. Method: Manipulation or Coercion · Impact: Financial Wellbeing · Resources: Money · Motivation: Personal Gain

Expert key. **Strong:** Password and Authentication (5) — shared credentials plus no multi-factor is the whole story; Account Lifecycle Management (7); Incident Response Planning (13) for the notification duty. **Partial:** Email and Browser Protections (12), Audit Logging (15), Cyber Insurance (21). **Weak here:** Network

Segmentation (18), Endpoint Detection (16) — nothing was installed on any machine.
Debrief.

- Six people share one password because it is genuinely convenient. What do you replace it with that they will actually use? (This is the Human Factors card in disguise.)
- Which of your purchases helps you tell four thousand donors what happened?
- Insurance may cover the cost. Does it cover the donor who stops giving?

Writing Your Own

A scenario that works has four properties. It names an organization concrete enough to picture. It states a consequence in human terms rather than technical ones. It has *more than one* defensible answer, or teams agree in ninety seconds. And it has at least one card that looks obviously right and is not — that card is where the argument happens.

Test a draft by asking what a team would buy with it, then asking whether a different team could reasonably buy something else. If the answer to the second question is no, the scenario is a quiz question rather than a game.

C. Facilitator Self-Check

Run this before your first session and after your third.

Before the first session

- ☐ I have read Section 3 (Quick Reference) and Section 7.
- ☐ Decks are sorted into Foundational / Extended / Advanced / modifiers.
- ☐ I have physical tokens, not a tally sheet.
- ☐ I know the four immediate-intervention situations in 7.4.
- ☐ I have a redraw available for participants who want a different Impact card, and I will offer it to the team rather than to an individual.
- ☐ I am prepared to explain Phase 1 only, then start.

After the third session

- ☐ Did teams argue? If not, tighten the budget or vary the deal.
- ☐ Did I intervene above Rung 2 more than twice per table? If so, I am intervening too early.
- ☐ Did any team move a threat to Not Likely / Not Severe unchallenged?
- ☐ Did non-majors speak as much as majors?
- ☐ Are justification scores rising across sessions?
- ☐ Did I supply an answer that a peer would have supplied within five seconds?

Feedback

This manual is a working document. Where a rule did not survive contact with your classroom, change it and note why — re-tiering costs, adjusting the budget, and cutting cards are all expected local adaptations.